Theoretical Knowledge: Incident Escalation Workflows

1. Core Concepts

1.1 Escalation Tiers — SOC Structure

A Security Operations Center operates on a **tiered model** where incidents are escalated based on severity, complexity, and required expertise.

SOC Tier Structure:

```
┌──────────────────────────────────────────────────────────────────┐
│                          SOC MANAGER                             │
│            Strategic oversight, reporting to CISO                 │
└──────────────────────────────┬───────────────────────────────────┘
                               │
┌──────────────────────────────▼───────────────────────────────────┐
│                     TIER 3 — Advanced Analysis                    │
│  • Threat hunting & APT investigation                             │
│  • Malware reverse engineering                                    │
│  • Forensic analysis & evidence preservation                      │
│  • Custom detection rule development                              │
│  • Incident commander for critical incidents                      │
│  Personnel: Senior Analysts, Threat Hunters, Forensic Analysts    │
└──────────────────────────────┬───────────────────────────────────┘
                               │ Escalation: Novel threats, APT,
                               │ forensic needs, executive impact
┌──────────────────────────────▼───────────────────────────────────┐
│                     TIER 2 — Investigation                        │
│  • Deep-dive investigation of escalated alerts                    │
│  • Log correlation and root cause analysis                        │
│  • Containment and eradication actions                            │
│  • IOC extraction and threat intelligence enrichment              │
│  • Incident documentation and timeline reconstruction             │
│  Personnel: SOC Analysts (Mid-Level), Incident Responders         │
└──────────────────────────────┬───────────────────────────────────┘
                               │ Escalation: Confirmed incidents,
                               │ high severity, multi-system impact
┌──────────────────────────────▼───────────────────────────────────┐
│                     TIER 1 — Triage & Monitoring                  │
│  • 24/7 monitoring of SIEM dashboards and alerts                  │
│  • Initial triage: True/False positive determination              │
│  • Basic containment (block IP, disable account)                  │
│  • Alert documentation and ticketing                              │
│  • Escalation of confirmed/suspicious alerts to Tier 2            │
│  Personnel: Junior SOC Analysts, Security Monitors                │
└──────────────────────────────────────────────────────────────────┘
```

Escalation Criteria:

Criteria	Tier 1 → Tier 2	Tier 2 → Tier 3

Severity	Medium or High severity confirmed	Critical severity, executive systems
Complexity	Multiple systems involved	APT indicators, zero-day exploitation
Scope	Lateral movement detected	Organization-wide compromise
Data Impact	Potential data access	Confirmed data exfiltration
Time	Investigation exceeds 30 minutes	Investigation exceeds 2 hours
Expertise	Requires deeper log analysis	Requires malware RE, forensics

Escalation Decision Matrix:

Alert Severity	Evidence of Compromise	Escalation Path
Low	No	Close as false positive
Low	Possible	Monitor and document
Medium	No	Investigate at Tier 1, monitor
Medium	Yes	**Escalate to Tier 2**
High	Any	**Immediately escalate to Tier 2**
Critical	Any	**Tier 2 + Notify Tier 3 + SOC Manager**

1.2 Communication Protocols

Effective incident communication is as critical as technical response. Structured communication ensures all stakeholders receive timely, accurate, and actionable information.

A. SITREP — Situation Report

A SITREP is a standardized format for communicating incident status to stakeholders.

SITREP Template:

```
╔═══════════════════════════════════════════════════════════╗
║                    SITUATION REPORT (SITREP)              ║
╟═══════════════════════════════════════════════════════════╢
```

```
╟ Incident ID:    INC-2025-0818-003                          ╟
╟ Date/Time:      2025-08-18 13:00:00 UTC                    ╟
╟ Severity:       HIGH                                       ╟
╟ Status:           ACTIVE — Under Investigation                 ╟
╟──────────────────────────────────────────────────────────────╟
╟ SITUATION:                                                 ╟
╟ Unauthorized access detected on Server-Y (10.0.1.55).      ╟
╟ Multiple failed logins followed by a successful logon from ╟
╟ IP 192.168.1.200 (matched to known C2 feed).               ╟
╟──────────────────────────────────────────────────────────────╟
╟ ACTIONS TAKEN:                                             ╟
╟ 1. Server-Y isolated from network via VLAN change          ╟
╟ 2. IP 192.168.1.200 blocked at perimeter firewall          ╟
╟ 3. Memory dump initiated via Velociraptor                  ╟
╟ 4. Escalated to Tier 2 for deep investigation              ╟
╟──────────────────────────────────────────────────────────────╟
╟ NEXT STEPS:                                                ╟
╟ 1. Complete forensic analysis of memory dump               ╟
╟ 2. Review all logs for lateral movement from Server-Y      ╟
╟ 3. Notify affected business unit (HR Department)           ╟
╟──────────────────────────────────────────────────────────────╟
╟ PREPARED BY:    SOC Analyst — Tier 1                       ╟
╟ DISTRIBUTION:   Tier 2 Lead, SOC Manager                   ╟
╚══════════════════════════════════════════════════════════════╝
```

B. Stakeholder Communication Matrix:

Stakeholder	What to Communicate	When	Format
Tier 2 Analyst	Full technical details, logs, IOCs	Immediately on escalation	SITREP + TheHive case
SOC Manager	Summary, severity, business impact	Within 15 min for High/Critical	SITREP (executive section)
CISO	Business impact, regulatory implications	Critical incidents only	Executive briefing

Legal/Compliance	Data breach scope, regulatory exposure	If PII/PHI affected	Formal report
Business Unit Owner	Impact to their systems, estimated recovery	After initial containment	Non-technical summary

C. Communication Channels:

Priority	Primary Channel	Secondary Channel
Critical	Phone call + TheHive	Slack/Teams (war room channel)
High	TheHive + Slack/Teams	Email
Medium	TheHive	Email
Low	TheHive	—

1.3 Automation in Escalation — SOAR

SOAR (Security Orchestration, Automation, and Response) tools automate repetitive escalation tasks, reducing Mean Time to Respond (MTTR) and freeing analysts for higher-value work.

What SOAR Automates:

Task	Manual Process	SOAR Automation
Ticket Creation	Analyst manually creates TheHive case	Auto-create case from SIEM alert
Alert Enrichment	Analyst manually checks VirusTotal, OTX	Auto-enrich with IOC reputation
Tier Assignment	Analyst decides and reassigns	Auto-assign based on severity rules
Containment	Analyst manually blocks IP on firewall	Auto-block via API integration
Notification	Analyst sends email/Slack message	Auto-send SITREP to distribution list

SOAR Playbook Example — Auto-Escalation:

```
│ Trigger: High     │
│ severity alert    │
│ in SIEM           │
└─────────┬─────────┘
          ▼
┌─────────────────┐     ┌─────────────────┐
│ 1. Enrich alert │────▶│ 2. Check IOC    │
│    with OTX,    │     │    against threat │
│    VirusTotal   │     │    feeds        │
└─────────────────┘     └────────┬────────┘
                                 ▼
                        ┌─────────────────┐
                   No   │ 3. IOC match    │  Yes
                  ┌─────│    found?       │─────┐
                  ▼     └─────────────────┘     ▼
         ┌──────────┐              ┌─────────────────┐
         │ 4a. Assign │            │ 4b. Create HIGH │
         │ to Tier 1  │            │ priority TheHive │
         │ for review │            │ case, assign    │
         └──────────┘              │ to Tier 2       │
         └─────────┬──────────┘
                                                ▼
                                   ┌─────────────────┐
                   │ 5. Send SITREP │
                                   │ to SOC Manager  │
                                   │ via Slack       │
                                   └─────────────────┘
```

Popular SOAR Platforms:

Platform	Type	Key Features
Splunk SOAR (Phantom)	Commercial	Visual playbook builder, 300+ integrations
Cortex XSOAR (Palo Alto)	Commercial	ML-based incident routing, war room
TheHive + Cortex	Open Source	Case management + automated analyzers
Shuffle	Open Source	Drag-and-drop workflow automation

2. Key Objectives

- Master workflows for escalating incidents efficiently across SOC tiers.
- Develop structured communication skills (SITREPs, executive briefings).
- Understand how SOAR tools automate escalation and reduce MTTR.
- Build confidence in making escalation decisions under pressure.

3. Study Resources

Resource	Focus Area	Link
NIST SP 800-61 Rev. 2	Computer Security Incident Handling Guide	https://csrc.nist.gov/publications/detail/sp/800-61/rev-2/final
SANS Incident Handler's Handbook	Communication templates, escalation workflows	https://www.sans.org/white-papers/33901/
Splunk SOAR Documentation	Playbook creation, automation concepts	https://docs.splunk.com/Documentation/SOAR
TheHive Project Documentation	Open-source case management and escalation	https://docs.strangebee.com/
FIRST — Incident Response Teams	Best practices for IR team communication	https://www.first.org/

4. Real-World Application: Capital One Breach (2019)

The Capital One breach highlighted escalation failures:

- A WAF misconfiguration allowed an insider (former AWS employee) to access 100 million customer records.
- **Escalation gap**: Despite automated alerts from a WAF detecting unusual access patterns, the alerts were not escalated with appropriate urgency.

- **Communication failure**: The breach was ultimately discovered through an **external tip** (responsible disclosure on GitHub), not through internal SOC escalation.
- **Lesson**: Even with detection capabilities, incidents go unaddressed without well-defined escalation workflows and clear ownership at each tier.

Document prepared as part of SOC Analyst Training — Theoretical Knowledge Module